

1. 防火墙通常预定义了三类安全区域，**受信区域 Trust**、**非军事化区域 DMZ** 和 **非受信区域 Untrust**，用户可以根据需要自行添加新的安全区域。
2. （1）防火墙的基本功能是 **隔离”与 访问控制”**。（3）网络安全域是指同一系统内根据信息的性质、使用主体、安全目标和策略等元素的不同来划分的不同逻辑子网或网络。
3. （1）每一个逻辑区域内部有相同的安全保护需求、互相信任、具有相同的安全访问控制和边界控制策略，且相同的网络安全域共享一样的安全策略。（2）**基于网络的检测与响应体系（NDR）**通过对网络流量产生的数据进行多手段检测和关联分析，主动感知传统防护手段无法发现的高级威胁，进而执行高效的分析和回溯，并智能的输出预警信息和处置建议，实现对高级威胁的闭环式管理。（3）在下一代防火墙所采用的单路径处理架构中，数据包经过一次解码，一次性匹配用户 ID、应用 ID、内容 ID，最终将匹配结果同步至安全策略引擎，决定放行或阻断，这是深度集成各安全功能的体现。
4. 判断一个防火墙产品的性能主要依靠**网络吞吐量、并发连接数、新建连接速率和应用层性能指标** 4 个性能指标。
5. 防火墙技术有**包过滤技术、应用代理技术、会话机制和状态检测、应用识别技术、内容检查技术等**。
6. 包过滤防火墙通过检查每个报文的**源地址、目的地址、传输协议、端口号、ICMP** 的消息类型等信息与预先配置的安全策略匹配情况，来决定是否允许该报文通过。
7. 11.1 过滤规则表是**静态**的，而会话表是**动态**的，会话表中记录了当前活动的合法连接，会随着数据包传输进行实时的更新。11.2 状态检测技术采用基于**连接**的状态检测机制。11.3 状态检测技术通过**规则表与会话表**间相互配合，对表中的各个连接状态因素加以识别。
8. 不同的安全域之间形成 **域间关系”**，防火墙上大部分规则都在域间配置。当报文在域间流动时，将会触发安全检查。域间方向的概念：报文从**低级别**的安全区域向**高级别**的安全区域流动时为**入/Inbound 方向**；报文从由**高级别**的安全区域向**低级别**的安全区域流动时为**出/Outbound 方向**。
9. IPv6 单播地址主要包括以下类型：**可聚合全球单播地址**，用于全球范围的路由通信，前缀为 **2000::/3**，类似于 IPv4 的公网地址。**链路本地地址**，仅限同一物理链路使用，前缀为 **FE80::/10**，自动配置且无法跨路由器传输。**唯一本地地址**，类似 IPv4 私有地址，前缀为 **FC00::/7**，具备全局唯一性但不可全球路由。
10. （1）用于区分将要做策略路由的流量，匹配条件包括：**报文源 IP 地址、目的 IP 地址、协议类型、应用类型**等，不同的防火墙可以设置的匹配条件略有不同。（2）在一条策略路由规则中，可以包含多个匹配条件，各匹配条件之间是 **与”**的关系，报文必须同时满足所有匹配条件，才可以执行后续定义的转发动作。
11. 防火墙模式主要包括工作模式有：**路由模式、透明模式、混合模式、旁路模式**。

12. **NAT No-PAT** 是一种 NAT 转换时只转换地址，不转换端口，实现私网地址到公网地址一对一的地址转换方式。适用于上网用户较少且公网地址数与同时上网的用户数量相同的场景。**NAPT** (Network Address and Port Translation) 是一种转换时同时转换地址和端口，实现多个私网地址共用一个或多个公网地址的地址转换方式。适用于公网地址数量少，需要上网的私网用户数量大的场景。Smart NAT 是 No-PAT 方式的一种补充。**Smart NAT** 是一种可以在 No-PAT 的 NAT 模式下，指定某个 IP 地址预留做 NAPT 方式的地址转换方式。适用于平时上网的用户数量少，公网 IP 地址数量与同时上网用户数基本相同，但个别时段上网用户数激增的场景。**Easy IP** 是一种利用出接口的公网 IP 地址作为 NAT 转后的地址，同时转换地址和端口的地址转换方式。

13. DHCP 服务器提供三种 IP 分配方式：**自动分配、动态分配、手动分配**。

14. **DNS 透明代理技术**除了能够提高**多链路带宽利用率**，更重要的是**减少**终端用户被恶意修改 DNS 带来的安全风险。

15. **代理 ARP** 是 ARP 协议的一个变种，一般是使用在没有配置默认网关和路由策略的网络上。

16. **安全联盟** (Security Association, SA) 是指 IPSec 中通信双方建立的连接。 顾名思义，通信双方结成盟友，使用相同的封装模式、加密算法、加密密钥、验证算法、验证密钥。 SA 由一个三元组来唯一标识，这个三元组包括：(1) **安全参数索引** (SPI) (2) **目的 IP 地址** (3) **安全协议号**)

17. IPSec VPN 提供了三种安全机制：**认证、加密和数据完整性**。

18. **SSL VPN** 技术是指：远程接入用户利用标准 Web 浏览器内嵌的**安全套接层** (Security Socket Layer, SSL) 封包处理功能，连接企业内部的 SSL VPN 服务器，然后 SSL VPN 服务器可以将报文转向给特定的内部服务器，从而使得远程接入用户在通过验证后，可访问企业内部的服务器资源。

19. QoS 根据网络质量和用户需求，通过不同的服务模型为用户提供服务。通常 QoS

提供以下三种服务模型：**Best-Effort Service** 模型、**Integrated Service** 模型、**综合服务模型**。

20. 实现**区分服务**的主要技术包括：**流分类**、**流量监管**、**流量整形**、**拥塞管理**、**拥塞避免**。

21. **拥塞避免**一般通过**丢弃报文**来实现。在拥塞发生和拥塞加剧时，通过采用特定的分组丢弃策略，为属于不同转发业务类别的流量权衡资源的分配。常用的分组丢弃策略包括：**尾丢弃**（Tail Drop）、**RED**（Random Early Detection）、**WRED**（Weighted Random Early Detection）。

22. 根据**分类规则**的不同，**流分类**分为**简单流分类 BA**（Behavior Aggregate）和**复杂流分类 MF**（Multi-Field）。

文件内容过滤是对用户上传和下载的文件内容中包含的**关键字进行过滤**。管理员可以控制对哪些应用传输的文件以及哪种类型的文件进行文件内容过滤。

23. **应用内容过滤**是对应用协议中包含的**关键字进行过滤**。针对不同应用，设备过滤的内容不同。邮件过滤主要使用 IP 地址检查和邮件内容过滤技术，它可以帮助局域网用户提高邮件系统的安全性。

24. **AAA** 是一个**提供网络访问控制安全**的模型，通常用于**用户登录设备或接入网络**。**AAA** 指的是**认证、授权、计费**。

25. （1）**802.1X** 协议是一种基于接口的**网络接入控制协议**。“**基于接口的网络接入控制**”是指，在局域网接入设备的接口这一级，接入设备通过认证来控制用户对网络资源的访问。每个物理接口内部包含有**受控端口**和**非受控端口**。（2）可以将 MAC 认证使用的用户名格式分为三种类型：**MAC 地址格式**、**固定用户名形式**、**DHCP 选项格式**。（3）Portal 认证通常也称为 **Web 认证**，用户可以主动访问已知的 Portal 认证网站，输入用户名和密码进行认证，这种开始 Portal 认证的方式称作**主动认证**。反之，如果用户试图通过 HTTP 访问其他外网，将重定向到 Portal 认证网站，从而开始 Portal 认证过程，这种方式称作**强制认证**。

26. （1）**PPPoE** 协议的工作流程包含**发现和会话**两个阶段，发现阶段是**无状态**的。发现阶段结束后，就进入标准的 PPP 会话阶段。（2）一旦 PPPoE 会话开始，PPP 数据就可以以任何其他的 PPP 封装形式发送。PPPoE 会话的 **SESSION-ID** 是不能改变的，并且必须是发现阶段分配的值。PPPoE 会话阶段主要分为 **LCP 协商阶段**、**认证阶段**、**IPCP 阶段**等，在这些阶段顺利完成后，就可以进行数据传输。

27. **单包攻击**的类型有：**畸形报文攻击**指攻击者发送大量有缺陷的报文，从而造成主机或服务器在处理这类报文时系统崩溃。**扫描类攻击**是一种潜在的攻击行为，不具备直接的破坏行为，通常是攻击者发动真正攻击前的网络探测行为。**特殊控制报文攻击**是一种潜在的攻击行为，不具备直接的破坏行为，攻击者通过发送特殊控制报文探测网络结构，

为后续发动真正的攻击做准备。

28. 防火墙防御 DNS Flood 采用 **TC 源认证方式**。防火墙对于 HTTP Flood 的防御主要依靠 **HTTP 协议**所支持的**重定向方式**。防御入侵的前提是要**先识别入侵行为**，网络中的报文多种多样，IPS 采用了**特征对比**的方式，通过**签名**来判断入侵行为。

29. 木马系统软件一般由**木马配置程序**、**控制程序**和**木马程序**（服务器程序）三部分组成。

问答题：

1. GB/T 20281—2015《信息安全技术 防火墙安全技术要求和测试评价方法》中对防火墙定义是什么？

部署于不同安全域之间，具备网络层访问控制及过滤功能，并具备应用层协议分析、控制及内容检测等功能，能够适用于 IPv4、IPv6 等不同的网络环境的安全网关产品。

2. 应用代理技术的原理是什么？有什么优缺点？

应用代理技术的原理是：

（1）应用层代理能实现比包过滤更加严格的安全策略。应用层代理不用依靠包过滤工具来管理进出防火墙的数据流，而是通过对每一种应用服务编制专门的代理程序，实现监视和控制应用层信息流的作用。

（2）基于代理的防火墙不会遇到传统数据包过滤防火墙的 ACK 攻击扫描问题。

（3）应用层代理主要针对应用级，可梳理应用级协议，来确保所有的数据交换都严格遵守协议消息级。

（4）应用层代理可以帮助优化性能。将经常访问的信息进行缓存，再次访问时无须向服务器发出新的请求。

应用代理技术的优点是：

（1）应用层网关支持可靠的认证并提供详细的注册信息。

（2）用于应用层的过滤规则更易配置和测试。

(3) 代理工作在客户机和真实服务器间, 完全控制会话, 可提供详细的日志和安全审计功能。

(4) 应用代理防火墙可以被配置成唯一的可被外部看见的主机, 从而隐藏内部网络的 IP 地址, 保护内部主机免受外部主机进攻。

(5) 通过代理访问因特网可以解决合法 IP 地址不够用的问题。

应用代理技术的缺点是:

(1) 当用户对内部网络网关的吞吐量要求较高时, 代理防火墙会成为内外网络间通信的瓶颈。

(2) 应用代理服务器存在兼容性问题。代理服务器通常具有解释应用层命令的功能, 因此, 可能需要提供很多不同的代理服务器, 而且每一种应用升级时, 一般代理服务程序也要升级, 所以能提供的服务和可伸缩性是有限的。

3. 试述 DPI 技术和 DFI 技术的区别

(1) 处理速度

DFI 不需进行拆包操作, 处理速度较快。

DPI 技术要逐包进行拆包操作, 并与后台数据库进行对比, 处理速度慢。

(2) 维护成本

DFI 维护成本较低。

基于 DPI 技术的带宽管理系统需要配合新协议和新型应用, 不断升级后台应用数据库, 维护成本较高。

(3) 识别准确率

DPI 采用逐包分析、模式匹配技术, 可以准确识别流量中的具体应用类型和协议。而 DFI 仅对流量行为分析, 只能对应用类型进行大致分类。

若数据包是经过加密传输的, 采用 DPI 方式的流控技术则不能识别其具体应用, 而 DFI 方式的流控技术则不受影响

4. 试述策略路由工作流程。

- (1) 当有多条策略路由规则时，防火墙会按照匹配顺序，先寻找第一条规则。
- (2) 如果满足第一条策略路由规则的匹配条件，则按照指定动作处理报文。
- (3) 如果不满足第一条规则的匹配条件，则会寻找下一条策略路由规则。
- (4) 如果所有的策略路由规则的匹配条件都无法满足，报文按照路由表进行转发，策略路由的匹配是在报文查找路由表之前完成，也就是说策略路由比路由的优先级高。

5. 什么是流量监管？如何通过 CAR 限制某类报文流量？什么是令牌桶 TB

流量监管 TP (Traffic Policing) 的典型应用是监督进入网络的某一流量的规格，把它限制在一个合理的范围之内，丢弃超出规格的流量，以保护用户的网络资源不受损害。

使用承诺访问速率 CAR (Committed Access Rate) 来限制某类报文的流量。首先，根据预先设置的匹配规则来对报文进行分类，然后针对不同的分类实施不同的限流策略。当流量符合策略设置的规格时，发送报文；当流量超出策略设置的规格时，直接丢弃超出规格的报文。CAR 通过令牌桶 TB (Token Bucket) 实现流量监管。令牌桶可以看作是一个存放令牌的容器，预先设定一定的容量。系统按用户设定的速度向桶中放置令牌，当桶中令牌满时，多出的令牌溢出，令牌不再增加。

6. 什么是流量整形？流量整形如何使用缓冲区和令牌桶来完成？

流量整形 TS (Traffic Shaping) 的典型作用是限制流出某一网络的某一连接的正常流量与突发流量，使这类报文以比较均匀的速度向外发送，是一种主动调整流量输出速率的措施。流量整形通常使用缓冲区和令牌桶来完成。当分组到来的时候，按照以下几种情况进行处理。

(1) 当不存在 GTS (General Traffic Shaping) 队列时，将分组长度与令牌桶内的令牌数目进行比较，如果令牌桶中有足够的令牌可以用来发送报文，则报文直接被发送；如果令牌桶中没有足够的令牌，则产生 GTS 队列，分组缓存在队列中。令牌桶按用户设定的速度向桶中放置令牌，在分组被发送的同时，令牌做相应的减少。当 GTS 队列中有分组的时候，GTS 按一定的周期从队列中取出分组进行发送，每次发送都会与令牌桶中的令牌数作比较，直到令牌桶中的令牌数减少到队列中的报文不能再发送或队列中的报文全部发送完毕为止。

(2) 当有 GTS 队列存在的时候，直接进入队列，等待 GTS 队列按照一定周期对队列中的分组进行调度转发。

(3) 当分组到来而发现 GTS 队列已满时，分组被丢弃。